

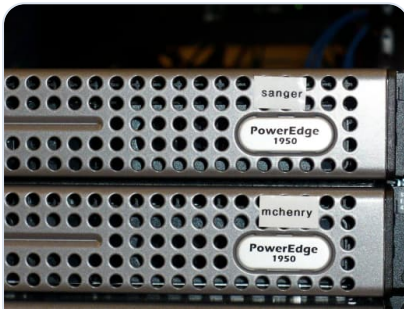
SÉCURITÉ DES APPLICATIONS WEB

Guide du TP 6 : configuration, dépendances et notation CVSS

TP 6 · Configuration, dépendances et CVSS

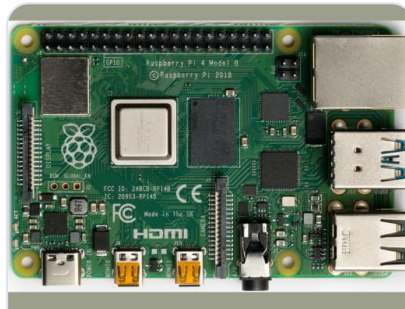


MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



Serveur

Fournit fichiers, messagerie ou site web aux autres



Raspberry Pi

Mini-ordinateur pour apprendre Linux à petit prix

Photos issues de Wikimedia Commons : Serveur, Florence Devouard, CC BY-SA 4.0 · Raspberry Pi, Laserlicht, CC BY-SA 4.0.

CADRE ET LIMITES

- ◆ Tu analyses uniquement des fichiers fournis ; ne teste jamais un système réel sans autorisation écrite.
- ◆ Les exemples ci-dessous utilisent des données inventées, pas celles du laboratoire.

Méthode générale

- 1 Lis d'abord la configuration comme une liste de contrôles simples : protocoles, en-têtes, cache et exposition involontaire.
- 2 Dans la racine du site, distingue les fichiers attendus des artefacts qui ne doivent jamais être publics : fichiers d'environnement, répertoires Git, archives et pages de diagnostic.
- 3 Pour les dépendances, compare toujours la version installée à la plage touchée, puis à la version corrigée.
- 4 Pour CVSS 3.1, applique la formule de FIRST telle quelle et arrondis toujours au dixième supérieur.



Liste de contrôle utilisée dans ce TP

- ◆ `server_tokens` ne doit pas exposer la version.
- ◆ `autoindex` doit rester désactivé sur un site public.
- ◆ TLS 1.0 et TLS 1.1 ne doivent pas être autorisés.
- ◆ Une page sensible ne doit pas être explicitement mise en cache en `public`.
- ◆ Les réponses HTML doivent envoyer l'en-tête HSTS (`Strict-Transport-Security`).
- ◆ Les réponses HTML doivent envoyer une politique `Content-Security-Policy`.
- ◆ Les réponses HTML doivent envoyer `X-Content-Type-Options: nosniff`.
- ◆ Les fichiers `.env`, les répertoires `.git/` (par exemple `.git/HEAD`), les archives de sauvegarde et les pages de diagnostic ne doivent pas être servis au public. Cette règle porte sur les fichiers réellement servis, pas sur le fichier de configuration.

Une règle violée compte pour un seul défaut, même si plusieurs lignes ou plusieurs protocoles la concernent.



Exemple bash : repérer des directives fragiles

BASH

```
cat > exemple-nginx.conf <<'EOF'
server_tokens on;
ssl_protocols TLSv1.2 TLSv1.3;
location /telechargements/ {
    autoindex off;
}
EOF
printf 'server_tokens actifs: '; grep -c '^server_tokens on;' exemple-nginx.conf
printf 'directives autoindex: '; grep -c 'autoindex' exemple-nginx.conf
```



Exemple PowerShell : compter les artefacts jamais publics

POWERSHELL

```
@(
    'Path;Status;Size'
    './.env;200;512'
    '/robots.txt;200;81'
    '/phpinfo.php;404;0'
) | Set-Content -Encoding UTF8 exemple-racine.csv
$rows = Import-Csv -Delimiter ';' -Encoding UTF8 exemple-racine.csv
$neverPublic = $rows | Where-Object { $_.Path -in './.env', '/phpinfo.php' -and $_.Status -eq '200' }
Write-Output $neverPublic.Count
```



Exemple bash : comparer des versions SemVer

BASH

```
cat > exemple-dependances.csv <<'EOF'
package;version
api-kit;1.4.2
ui-kit;2.0.0
EOF
printf 'plus ancien que 1.4.4: '; awk -F';' 'NR==2 { print ($2 < "1.4.4") ? "à vérifier" : "ok" }' exemple-dependances.csv
printf 'ordre naturel: '; printf '%s\n' 1.4.2 1.4.4 2.0.0 | sort -V | tail -n 1
```



Exemple PowerShell : comparer des versions

POWERSHELL

```
$installed = [version]'2.3.4'
$fixed = [version]'2.3.7'
if ($installed -lt $fixed) { Write-Output 'mise à jour requise' } else { Write-Output 'version déjà corrigée' }
```



CVSS 3.1 : formule à utiliser

- ◆ $ISS = 1 - (1 - C) \times (1 - I) \times (1 - A)$
- ◆ Portée inchangée : $Impact = 6,42 \times ISS$
- ◆ Portée modifiée : $Impact = 7,52 \times (ISS - 0,029) - 3,25 \times (ISS - 0,02)^{15}$
- ◆ $Exploitabilité = 8,22 \times AV \times AC \times PR \times UI$
- ◆ Si $Impact \leq 0$, la note vaut $0,0$.
- ◆ Portée inchangée : $Arrondi_sup(min(Impact + Exploitabilité, 10))$
- ◆ Portée modifiée : $Arrondi_sup(min(1,08 \times (Impact + Exploitabilité), 10))$
- ◆ **Arrondi_sup** signifie : le plus petit nombre à une décimale supérieur ou égal à la valeur.

MÉTRIQUE	VALEURS UTILES
AV	N 0,85; A 0,62; L 0,55; P 0,2
AC	L 0,77; H 0,44
PR	N 0,85; L 0,62 ou 0,68; H 0,27 ou 0,5 selon la portée
UI	N 0,85; R 0,62
C, I, A	H 0,56; L 0,22; N 0

Qualification de la note de base :

QUALIFICATION	NOTE
Aucune	0,0

QUALIFICATION	NOTE
Faible	0,1 à 3,9
Moyenne	4,0 à 6,9
Élevée	7,0 à 8,9
Critique	9,0 à 10,0



Exemple de calcul manuel

Prends le vecteur fictif `CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:H/I:L/A:N`.

- 1 Remplace chaque lettre par sa valeur.
- 2 Calcule `ISS`, puis `Impact`, puis `Exploitabilité`.
- 3 Additionne, applique `min(..., 10)`, puis l'arrondi supérieur au dixième.
- 4 Convertis enfin la note en qualification : faible, moyenne, élevée ou critique.



Dans la visionneuse du site

- ◆ Ouvre d'abord `swb-tp6-nginx.conf` pour relever les directives évidentes.
- ◆ Ouvre ensuite `swb-tp6-racine-site.txt` pour lister ce qui répond encore en `200`.
- ◆ Termine par `swb-tp6-dependances.csv` et `swb-tp6-avis.csv` pour faire la comparaison paquet par paquet.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).